Table 3.5 How the browser reacts to server responses *(continued)*

Client request	Server response	Browser behavior
`Origin: http://localhost:1111`	`Access-Control-Allow-Origin: http://localhost:1111`	Success.
`Origin: http://localhost:1111`	`Access-Control-Allow-Origin: http://othersite.com`	Error. Access-Control-Allow-Origin header doesn't match Origin header.

What does it mean for the browser to reject the request? It means that the browser doesn't forward any of the response information to the client. The client only knows that an error occurred, but it doesn't receive any additional information about what the error was. This can be frustrating when debugging CORS requests, because it's hard to programmatically infer when a request fails due to CORS rather than some other reason. Chapter 7 delves more into how to debug failing CORS requests.

When the browser rejects the CORS request, it doesn't send the response to the client. But the actual HTTP request is still made to the server, and the server still sends back an HTTP response. It may seem a little odd for the browser to make an HTTP request only to have it rejected. But this must be done because the browser has no way of knowing whether or not CORS is supported without first asking the server by making the request. Figure 3.22 shows the CORS flow when the server rejects the CORS request. The request is still sent to the server ❶. When the browser notices that there is no Access-Control-Allow-Origin header (or the header doesn't match the origin), it triggers an error on the client, and doesn't forward the response details ❷.

Note that this mechanism for rejecting CORS requests also protects servers that know nothing about CORS. Any server that was operational before CORS was introduced needs to be protected from unauthorized CORS requests. If a server knows nothing about CORS, but it receives a CORS request, the server's response will not have an Access-Control-Allow-Origin header, and the request will be rejected. The CORS request will succeed only if the server explicitly opts-in to the request.

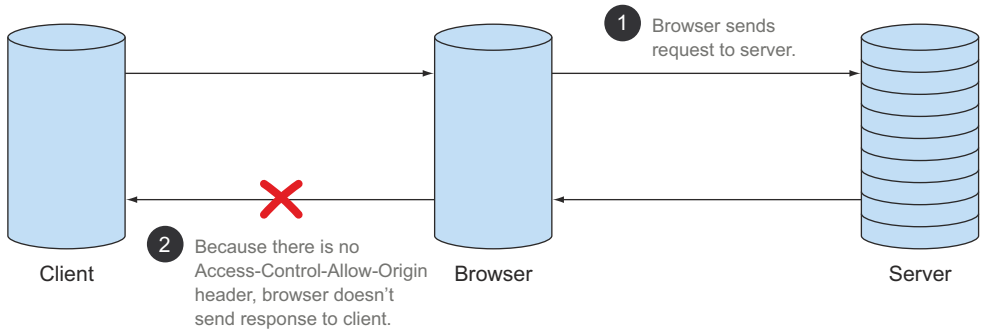


Figure 3.22 CORS flow for a rejected CORS request